

ffuf — دليل الاستخدام العملي

Directory/VHost/parameter fuzzing وال filters وال extensions وال headers/cookies وربطه بـBurp.

➤ Abdullah Nasser Almsan – Personal Pentest Reference

ملاحظة استخدام: استخدمه ضمن Web lab المصرح. كلمة fuzzing هنا تعني توليد طلبات كثيرة نسبيًا، فاضبط النطاق والسرعة.

VERIFY

يدوي

FILTER

fc/fs/fw

FUZZ

الموضع

BASELINE

response

الفهرس

- 4. Parameter fuzzing
- 5. Headers / Cookies / Burp
- 6. Workflow

- 1. قاعدة FUZZ
- 2. Filtering
- 3. VHost discovery

1. قاعدة FUZZ

ffuf يحتاج wordlist ومكان FUZZ في الطلب.

KALI TERMINAL Directory discovery

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ
```

KALI TERMINAL Extensions

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ -e .php,.txt,.html
```

2. Filtering

أهم سبب لتعلم ffuf بدل قراءة آلاف النتائج.

الخيار	المعنى
-fc	Filter status codes
-fs	Filter response size
-fw	Filter word count

الخيار	المعنى
-fl	Filter line count
-fr	Filter regex
-mc	Match status codes

مثال size filter KALI TERMINAL

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ -fs [BASELINE_SIZE]
```

خذ baseline لصفحة غير موجودة أولاً. إذا كل paths ترجع 200، filter بالsize/words بدل status فقط.

3. VHost discovery

غير Host header عندما DNS لا يكشف vhosts.

VHost KALI TERMINAL

```
ffuf -w [WORDLIST] -u http://[TARGET]/ -H "Host: FUZZ.[DOMAIN]" -fs [BASELINE_SIZE]
```

4. Parameter fuzzing

FUZZ يمكن أن يكون اسم parameter أو قيمته.

GET parameter name KALI TERMINAL

```
ffuf -w [PARAMS] -u "http://[TARGET]/page?FUZZ=test" -fs [BASELINE_SIZE]
```

GET value KALI TERMINAL

```
ffuf -w [VALUES] -u "http://[TARGET]/page?id=FUZZ" -fc 404
```

POST body AUTHORIZED WEB LAB

```
ffuf -w [VALUES] -u http://[TARGET]/login -X POST -d "username=admin&password=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -fc 401
```

Credential fuzzing قد يسبب lockout. استخدم فقط إذا اللاب يطلبه.

5. Headers / Cookies / Burp

كرر request قريب من المتصفح.

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ -b "session=[VALUE]"
```

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ -x http://127.0.0.1:8080
```

استخدم Threads منخفضة إذا تريد مراجعة الطلبات في Burp.

Workflow .6

.Baseline → FUZZ → Filter → Verify

الخطوة	العمل	السبب
1	Baseline	افهم response الخاطئ
2	FUZZ	حدد المكان المراد تغييره
3	Wordlist	اختر قائمة مناسبة
4	Filter	fc/fs/fw
5	Verify	افتح النتائج المهمة يدويًا
6	Save	استخدم output إذا احتجت Evidence

مرجع مراجعة سريع للتعلم والاختبارات المصرح بها فقط.

Refs: <https://github.com/ffuf/ffuf> · <https://github.com/ffuf/ffuf/wiki>